

MAINCRAFTS TECHNOLOGY

www.maincrafts.com | hr@maincrafts.com

CYBERSECURITY INTERNSHIP PROGRAM

Task-1: Threat Intelligence Report

Cybersecurity Threats Landscape & Defense Measures (2024–2025)

Prepared by:

PARV PATEL

Cybersecurity Analyst Intern

Submission Date: **11/08/26**

Prepared as part of the Cybersecurity & Ethical Hacking Task-1 Internship Assignment

Table of Contents

1. Introduction to Cybersecurity.....	3
2. Major Modern Cyber Threats (2024–2025).....	4
2.1 AI-Powered Phishing Attacks	4
2.2 Ransomware-as-a-Service (RaaS).....	5
2.3 Cloud Security Misconfigurations	6
2.4 IoT Vulnerabilities.....	7
2.5 Zero-Day Exploits.....	8
3. Conclusion and Future Scope	9
References	10

1. Introduction to Cybersecurity

What is Cybersecurity?

Cybersecurity is the practice of protecting computer systems, networks, applications, and data from unauthorized access, disruption, theft, or damage. It combines technology, processes, and human awareness to defend digital assets against an ever-growing range of threats, from lone hackers exploiting a single vulnerability to organized criminal groups running large-scale extortion operations. Modern cybersecurity spans several interconnected domains, including network security, application security, cloud security, endpoint protection, identity and access management, and incident response.

Why is it Important for Individuals and Businesses?

For individuals, cybersecurity protects personal identity, financial information, and private communications from being stolen or misused. A single compromised account can lead to financial fraud, identity theft, or reputational harm. For businesses, the stakes are even higher: a successful cyberattack can halt operations, expose customer and employee data, trigger regulatory penalties, and cause lasting reputational damage. As organizations digitize more of their operations — moving to the cloud, connecting more devices, and relying on third-party software — their attack surface grows, making robust cybersecurity a business necessity rather than an optional IT function.

Current Relevance

Cybercrime has continued to escalate through 2024 and 2025, driven by three converging trends. First, digital dependency has deepened, with critical services — healthcare, finance, energy, and government — now running on interconnected digital infrastructure that, if disrupted, has real-world consequences. Second, cybercriminal operations have professionalized: ransomware is now sold as a subscription service, and stolen data trades openly on dark-web marketplaces. Third, artificial intelligence has become a force multiplier for attackers, enabling hyper-realistic phishing emails, voice and video deepfakes, and automated vulnerability discovery at a scale and speed defenders have never faced before. Together, these trends make continuous vigilance, layered defenses, and security awareness training more critical than ever.

2. Major Modern Cyber Threats (2024–2025)

The following five threats represent some of the most significant and fastest-growing risks observed across the global threat landscape in 2024 and 2025. Each threat is analyzed for its impact on individuals and organizations, illustrated with a real-world case, and paired with practical preventive measures.

2.1. AI-Powered Phishing Attacks

Emails, deepfakes, and social engineering supercharged by generative AI.

Generative AI has transformed phishing from crude, typo-ridden emails into highly convincing, personalized attacks. Attackers now use large language models to craft flawless, context-aware messages, and use voice-cloning and video-deepfake tools to impersonate executives in real time during calls or video conferences. According to Microsoft's 2025 Digital Defense Report, AI-automated phishing emails achieve dramatically higher click-through rates than traditional attempts because of their linguistic fluency and contextual relevance. Deepfake-enabled voice phishing ("vishing") has also surged, with threat intelligence providers reporting a massive rise in deepfake-enabled voice scams in early 2025 compared to the previous year.

Impact Analysis

Target	Impact Description
Individuals	Individuals can be tricked into revealing passwords, banking details, or one-time codes through convincing fake emails, calls, or messages that appear to come from trusted contacts, banks, or government agencies, leading directly to financial loss and identity theft.
Organizations	Organizations face large-scale financial fraud when employees are deceived into authorizing payments or sharing credentials; the resulting incidents also cause operational disruption, loss of client trust, regulatory scrutiny, and reputational damage that can persist long after the incident is resolved.

Real-World Case Study

In February 2024, an employee at Arup, a UK-based multinational engineering firm, was deceived into transferring approximately USD 25 million after joining a video conference in which every other participant — including a person appearing to be the company's Chief Financial Officer — was an AI-generated deepfake. The employee had initially been suspicious of a phishing email but was reassured after seeing and hearing familiar-looking executives on the call. The incident is now regarded as one of the most significant publicly documented deepfake-enabled fraud cases and illustrates how AI can defeat traditional "verify by video call" safeguards.

Preventive Measures

- Verify high-value or unusual payment requests through a second, independent communication channel (e.g., a phone call to a known number) rather than relying on the original email or video call alone.
- Deploy AI-aware email security and anomaly-detection tools capable of flagging synthetic or unusually persuasive content.
- Conduct regular security awareness training that specifically covers deepfake and AI-generated social engineering tactics.
- Enforce multi-person approval (dual control) for large financial transactions, regardless of who appears to authorize them.

2.2. Ransomware-as-a-Service (RaaS)

Ready-made ransomware kits that let low-skill criminals launch professional-grade extortion attacks.

Ransomware-as-a-Service has turned ransomware into a subscription business model. Developers build and maintain the malware, negotiation infrastructure, and leak sites, then lease these tools to "affiliates" in exchange for a share of the ransom. This division of labor has dramatically lowered the technical skill required to launch a devastating attack. Groups such as LockBit, ALPHV/BlackCat, and RansomHub dominated the RaaS ecosystem through 2024, frequently combining data encryption with "double extortion" — stealing sensitive data before encrypting it and threatening to leak it if the ransom is not paid.

Impact Analysis

Target	Impact Description
Individuals	Individuals whose personal data is held by an affected organization face exposure of medical records, financial details, or other sensitive information, and may experience downstream identity theft or fraud even though they were not directly attacked.
Organizations	Organizations suffer significant operational downtime, costly recovery and remediation efforts, potential ransom payments, regulatory fines for data protection failures, and long-term reputational and customer-trust damage — costs that can run into hundreds of millions of dollars for large incidents.

Real-World Case Study

In February 2024, the ALPHV/BlackCat ransomware group — operating under the RaaS model — attacked Change Healthcare, a major U.S. healthcare technology provider owned by UnitedHealth Group. The attack disrupted prescription processing and payment systems nationwide for over a month, affecting pharmacies, hospitals, and patients across the United States. UnitedHealth Group later disclosed total costs related to the attack exceeding USD 870 million, and reports indicated a ransom of around USD 22 million was paid, making it one of the most damaging healthcare cyberattacks on record.

Preventive Measures

- Maintain regular, encrypted, and offline (air-gapped) backups, and routinely test the restoration process.
- Apply the Zero Trust security model, limiting lateral movement even if one system is compromised.
- Keep systems patched through disciplined, regular patch management to close known vulnerabilities exploited by affiliates.
- Deploy endpoint detection and response (EDR) tools and network segmentation to contain outbreaks quickly.

2.3. Cloud Security Misconfigurations

Human error in cloud setup exposing sensitive data on AWS, Azure, and GCP.

As organizations migrate infrastructure to the cloud, misconfigured storage buckets, overly permissive access policies, and exposed credentials have become one of the leading causes of data breaches. Under the cloud shared-responsibility model, providers secure the underlying infrastructure, but customers remain responsible for correctly configuring storage, identity, and access controls. Research published in 2025 found that a substantial share of cloud storage buckets remain publicly accessible due to default or careless settings, and long-lived, leaked credentials continue to be one of the most common root causes of publicly reported cloud breaches.

Impact Analysis

Target	Impact Description
Individuals	Individuals whose personal or payment data is stored in an exposed cloud bucket face identity theft, financial fraud, and loss of privacy, often without any warning that their information was ever at risk.
Organizations	Organizations suffer direct data-loss incidents, regulatory penalties under data protection laws, loss of customer trust, and — because these exposures are often discovered by security researchers or scanners before the company notices — significant reputational embarrassment.

Real-World Case Study

In 2024, security researchers discovered that Football Australia had misconfigured its AWS S3 storage buckets, leaving plaintext access keys exposed in its website source code. The exposed keys granted access to 127 digital storage containers containing personal details of football players, attendee purchase information, and internal source code. The Cloud Security Alliance later cited this incident as a textbook example of the "Misconfiguration and Inadequate Change Control" risk category in its 2025 Top Threats to Cloud Computing report.

Preventive Measures

- Enforce the principle of least privilege for all cloud identities and enable public-access blocking by default on storage services.
- Never hard-code credentials or access keys in source code; use secrets-management services and rotate keys regularly.
- Continuously monitor cloud configurations with automated tools (CSPM/CNAPP) to detect configuration drift from secure baselines.
- Enable detailed access logging and alerting so unauthorized access attempts are detected quickly rather than discovered by outsiders.

2.4. IoT Vulnerabilities

Smart devices — cameras, routers, and DVRs — hijacked into massive botnets.

The explosive growth of Internet of Things (IoT) devices — from home routers and IP cameras to industrial sensors — has outpaced the security built into them. Many devices ship with weak or default credentials, lack automatic patching mechanisms, and remain internet-exposed for years without updates. Threat actors exploit these weaknesses to build massive botnets used for distributed denial-of-service (DDoS) attacks, credential theft, and proxy-for-hire services. SonicWall's 2025 Cyber Threat Report recorded a sharp rise in IoT malware attacks in 2024, with tens of millions of attacks against IP cameras alone.

Impact Analysis

Target	Impact Description
Individuals	Individuals' home routers, cameras, or smart devices can be silently conscripted into a botnet, degrading their internet performance, exposing their home network to further compromise, and potentially exposing footage or data captured by hijacked cameras.
Organizations	Organizations face large-scale DDoS attacks that knock websites and services offline, reputational damage, and — in the case of compromised industrial or medical IoT devices — potential safety risks in operational technology environments.

Real-World Case Study

First identified in late 2024, the Aisuru IoT botnet — built on Mirai-derived malware — rapidly infected hundreds of thousands of routers, DVRs, and IP cameras worldwide by exploiting weak credentials and unpatched firmware. By late 2025, Aisuru and its variant "Kimwolf" were launching record-breaking DDoS attacks exceeding 29–31 terabits per second, among the largest ever recorded, prompting a coordinated law-enforcement disruption effort. The case demonstrates how a near-decade-old malware family (Mirai) continues to compromise poorly secured consumer IoT devices at an ever-growing scale.

Preventive Measures

- Change default device passwords immediately upon setup and use strong, unique credentials for every device.
- Keep IoT firmware updated and, where possible, choose vendors that provide regular security patches.
- Segment IoT devices onto a separate network from critical business or personal systems to limit lateral movement.
- Disable unnecessary remote-access features and close unused ports on routers and smart devices.

2.5. Zero-Day Exploits

Attacks on unpatched, previously unknown vulnerabilities before a fix exists.

A zero-day exploit targets a software vulnerability that is unknown to the vendor and has no available patch, giving defenders "zero days" of warning. In 2024, threat intelligence firm Mandiant observed that the most exploited vulnerabilities were concentrated in enterprise edge devices such as VPNs, firewalls, and routers — infrastructure that sits at the perimeter of corporate networks and, once compromised, offers attackers a direct path inside. Nation-state espionage groups and ransomware gangs alike have increasingly prioritized zero-days in widely used enterprise software because a single flaw can be leveraged against thousands of victims simultaneously.

Impact Analysis

Target	Impact Description
Individuals	Individuals are rarely targeted directly, but they are frequently affected indirectly when a zero-day in enterprise software used by their bank, employer, hospital, or government agency leads to the exposure of their personal records.
Organizations	Organizations face unauthenticated remote access to internal networks, data theft, espionage, and extended incident-response costs, since by definition no patch exists at the time of exploitation, making early detection and rapid response essential.

Real-World Case Study

Beginning in mid-December 2024, threat intelligence firm Mandiant identified active zero-day exploitation of CVE-2025-0282, a critical buffer-overflow vulnerability in Ivanti Connect Secure VPN appliances, by a suspected China-linked espionage group. This followed an earlier pair of Ivanti zero-days exploited throughout early 2024 by multiple nation-state clusters, which the U.S. Cybersecurity and Infrastructure Security Agency (CISA) responded to with an emergency directive after its own systems were affected. The repeated targeting of the same VPN product illustrates how enterprise edge devices have become a preferred entry point for sophisticated attackers.

Preventive Measures

- Apply vendor patches and emergency security directives as soon as they are released, prioritizing internet-facing edge devices.
- Deploy intrusion detection/prevention systems (IDS/IPS) and network monitoring to catch anomalous behavior even without a known signature.
- Adopt a Zero Trust architecture so that a single compromised device does not grant broad network access.
- Maintain an incident response plan and threat-intelligence subscription to learn about active exploitation as early as possible.

3. Conclusion and Future Scope

The five threats examined in this report — AI-powered phishing, Ransomware-as-a-Service, cloud misconfigurations, IoT vulnerabilities, and zero-day exploits — share a common thread: each has grown more dangerous by combining technical exploitation with either automation, human error, or organizational scale. Attackers are no longer limited to lone actors; they operate as professionalized, service-based ecosystems that lower the barrier to entry for sophisticated cybercrime, while AI simultaneously raises the sophistication of social engineering to levels that can deceive even trained employees.

Proactive cybersecurity is no longer optional. Waiting to react after a breach occurs is far more costly — financially, operationally, and reputationally — than investing in prevention: strong access controls, regular patching, employee awareness training, and a Zero Trust mindset. Because attackers continuously adapt their techniques, defenders must treat cybersecurity as a continuous discipline rather than a one-time project. Continuous learning, threat-intelligence monitoring, and regular security audits are essential to keeping pace with an evolving threat landscape.

Looking ahead, the increasing use of artificial intelligence by both attackers and defenders will likely define the next phase of cybersecurity. Organizations that invest early in AI-aware detection tools, robust cloud governance, IoT device hygiene, and a culture of security awareness will be far better positioned to withstand the threats of 2025 and beyond.

References

1. Microsoft. (2025). Microsoft Digital Defense Report 2025.
2. Adaptive Security. (2025). AI Phishing Examples: Deepfakes, Voice & Email Fraud. <https://www.adaptivesecurity.com>
3. CompassMSP. (2024). AI-Generated Deepfakes: The Arup Case and Business Governance. <https://compassmsp.com>
4. TechTarget. (2024). 10 of the Biggest Ransomware Attacks in 2024. <https://www.techtarget.com>
5. Analyst1. (2024). Ransomware & Extortion Activity in 2024: A Year in Review. <https://analyst1.com>
6. Cloud Security Alliance. (2025). Top Threats to Cloud Computing Deep Dive 2025 — Football Australia Case Study. <https://cloudsecurityalliance.org>
7. ClearPoint Digital. (2025). Misconfigured, Exposed, Forgotten: Why S3 Is Still a Problem in 2025. <https://clearpoint.digital>
8. SonicWall. (2025). 2025 Cyber Threat Report.
9. Asimily. (2026). The Top Internet of Things (IoT) Cybersecurity Breaches. <https://asimily.com>
10. Krebs on Security. (2026). Feds Disrupt IoT Botnets Behind Huge DDoS Attacks. <https://krebsonsecurity.com>
11. Mandiant / Google Threat Intelligence Group. (2025). M-Trends 2025 Report.
12. Cybersecurity Dive. (2025). Ivanti Customers Confront New Zero-Day with Suspected Nation-State Nexus. <https://www.cybersecuritydive.com>
13. CISA — Cybersecurity & Infrastructure Security Agency. Official cyber alerts. <https://www.cisa.gov>
14. OWASP Foundation. OWASP Top 10 Web Application Security Risks. <https://owasp.org>